LESSON 3.1 | Lesson notes

SQL Injection

Overview

SQL injection happens when user input is placed inside an SQL command as text. If a login query is built as "SELECT * FROM users WHERE name = '" + name + "'" and a user types ' OR '1'='1, the condition becomes true for every row. Attackers use the same trick to read or delete whole tables. The defence is to use parameterised queries, where values are sent separately from the SQL, and to give the database account only the permissions the application needs. Validating input helps but is never a substitute.

Key points

- Part of: Web Security
- About 20 minutes
- Try the example yourself, then check it

How to use this handout

1. Read the overview first, then work through the key points in order.
2. Write down anything you are unsure about and ask in the course forum.
3. Use page 2 to plan your practice and keep notes.

LESSON 3.1 | Lesson notes

SQL Injection

Practice checklist

- [ ] Read: SQL Injection
- [ ] Try the example from the lesson
- [ ] Explain the main idea in your own words
- [ ] Answer the related questions
- [ ] Ask about anything unclear in the forum

My notes